Web Application Penetration Testing (OWASP Top 10 Focus)

- Week-1 & Week-2 Report:-

Week 1 – Setup & Reconnaissance

Objective

To understand OWASP Top 10 vulnerabilities and set up a testing environment for web application penetration testing.

Tasks Performed

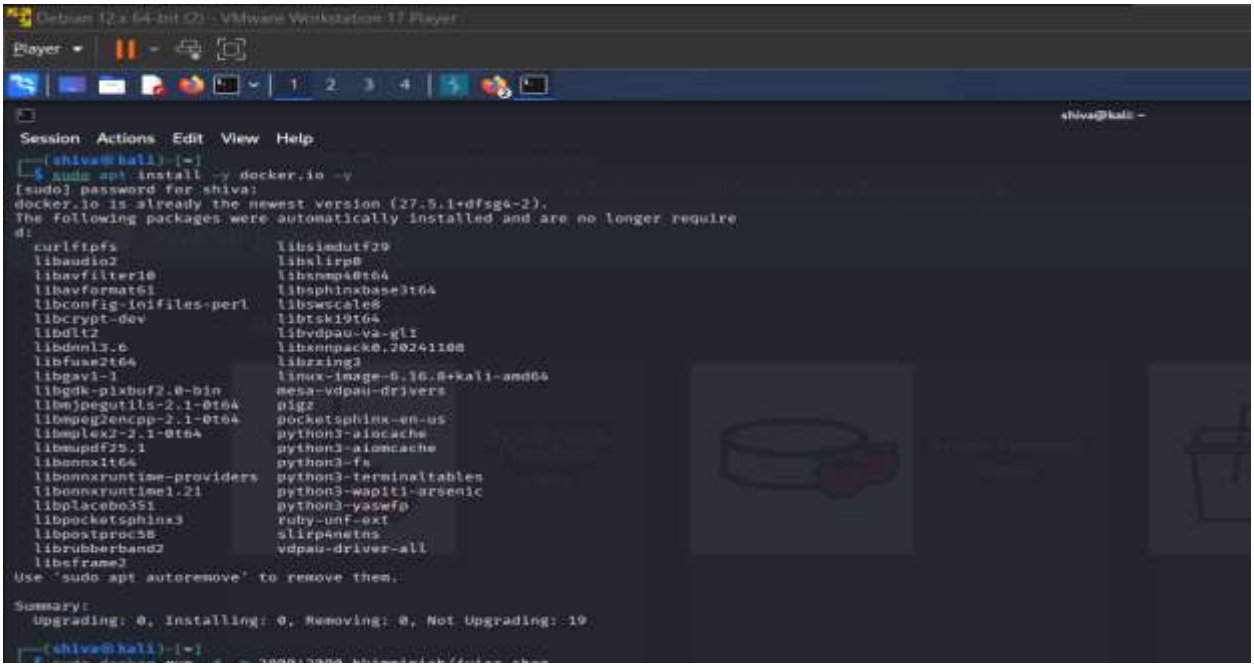
- Studied OWASP Top 10 vulnerabilities:
    - Injection
    - Broken Authentication
    - XSS
    - Sensitive Data Exposure
- Installed and configured:
    - Kali Linux (VMware)
    - Docker

Environment Setup

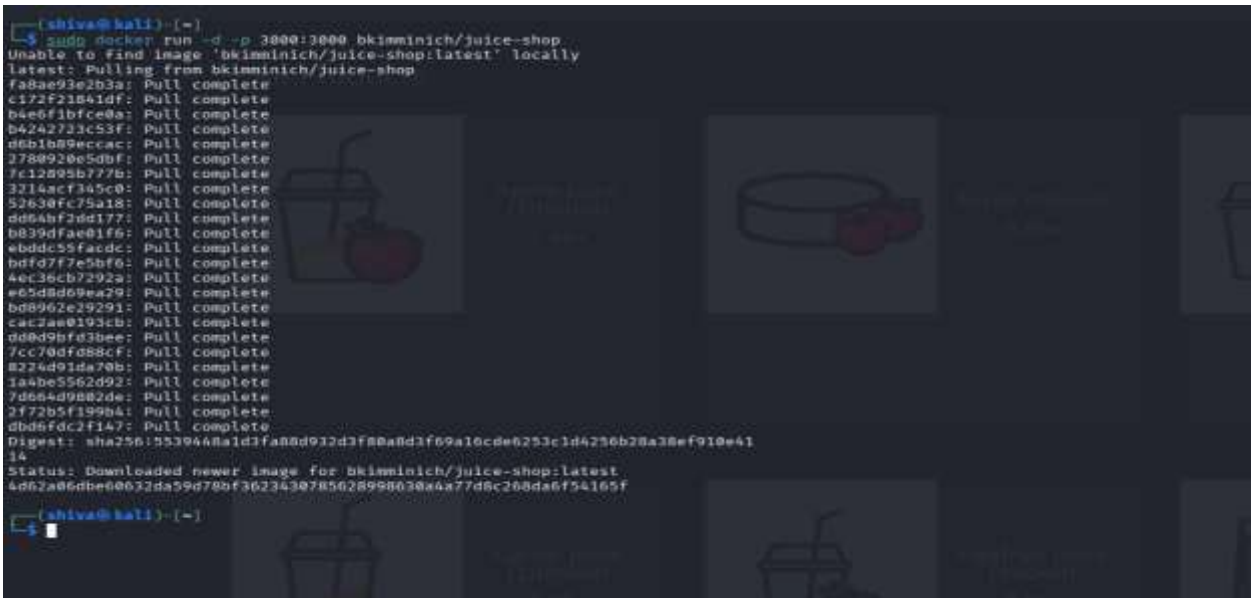
- Installed Docker and verified installation
- Deployed OWASP Juice Shop using:

- sudo docker run -d -p 3000:3000 bkimminich/juice-shop

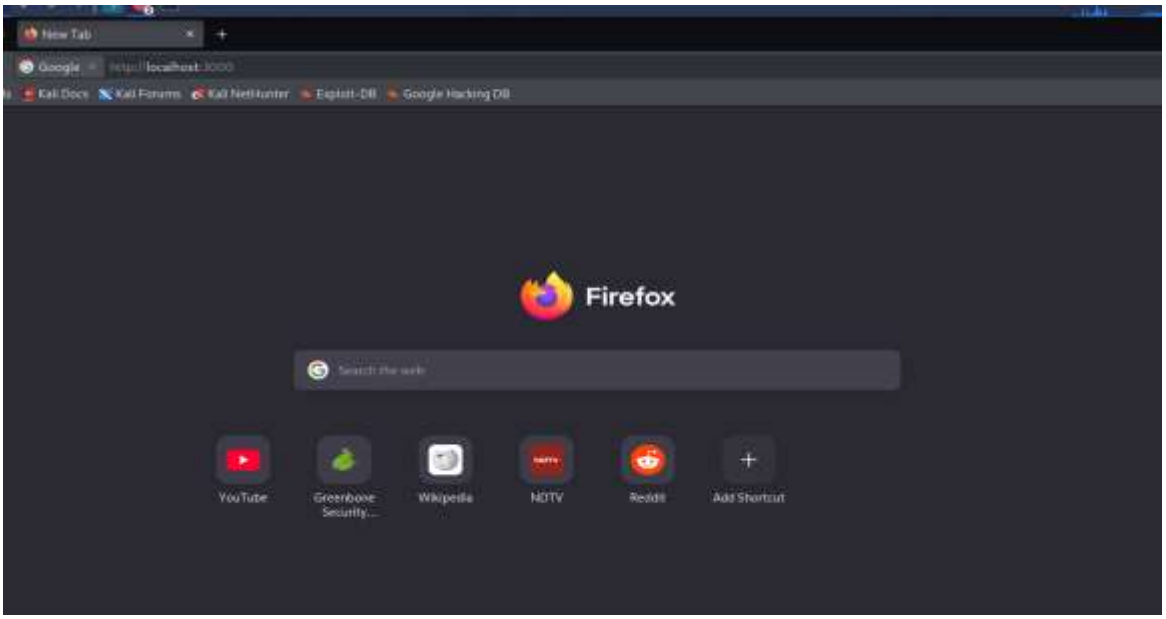
The Docker environment was set up successfully on Kali Linux using the apt install docker.io command. The system confirmed that Docker was already installed with the latest version, ensuring a ready-to-use containerization platform. Several dependent packages were also listed as installed, indicating proper configuration of required libraries. This step validated that the environment was prepared for deploying vulnerable applications. No errors were encountered during installation, confirming system stability. Docker was then used to host the OWASP Juice Shop application for further penetration testing activities.



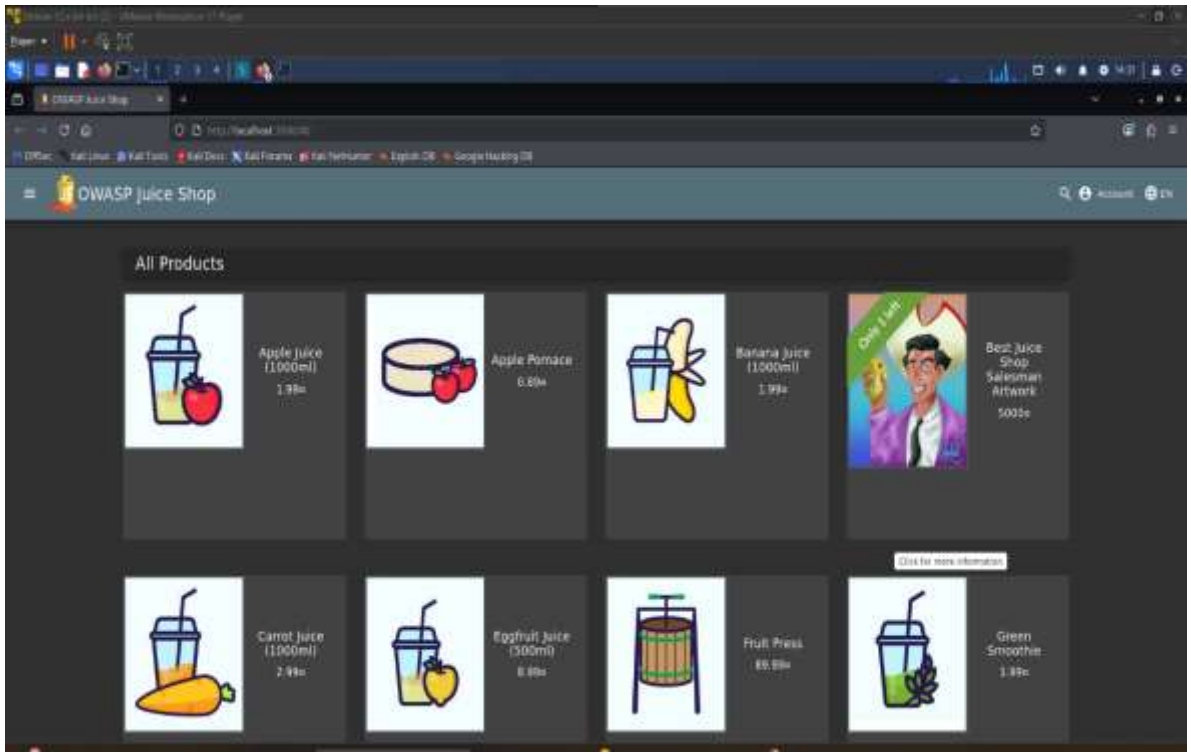
- Sudo docker run -d -p 3000:3000 bkimminich/juice-shop



- Accessed application at-http://localhost:3000

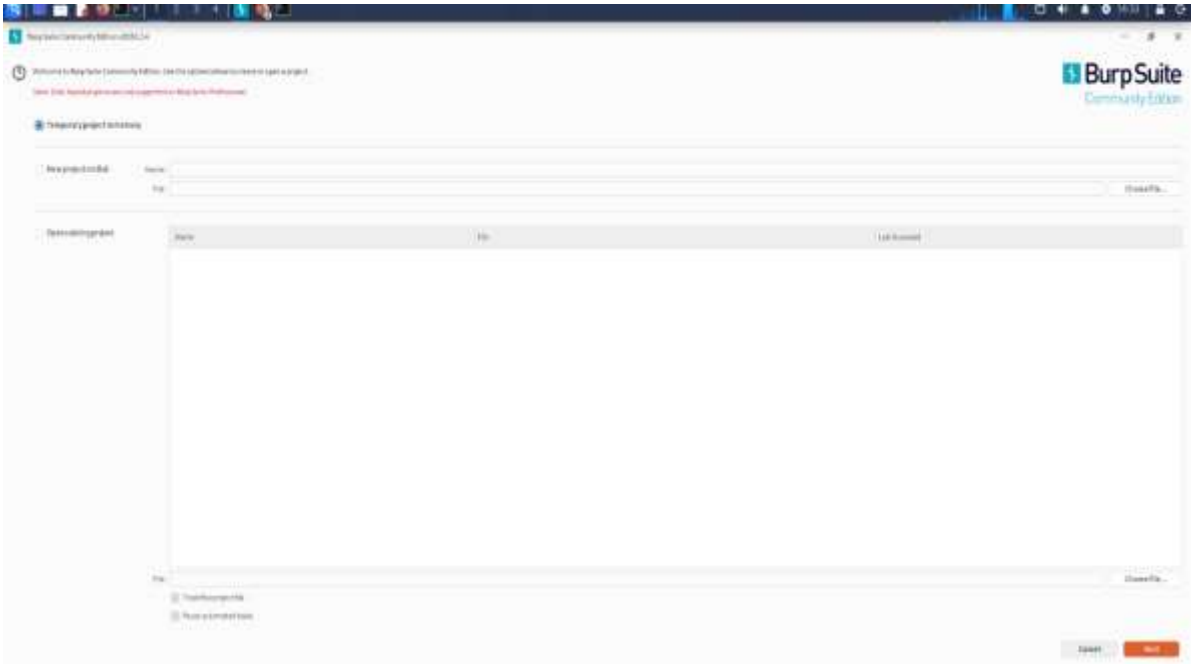


- OWASP Juice Shop homepage (All Products view)



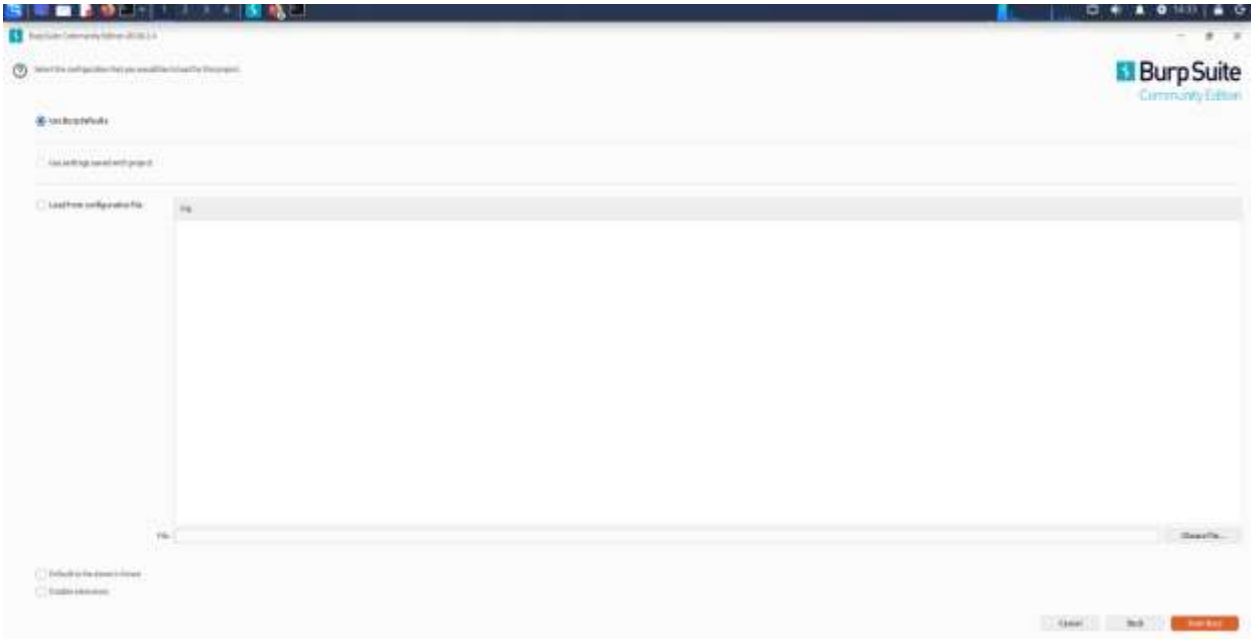
Burp Suite Configuration

- Started Burp Suite Community Edition
- Selected:
    - Temporary Project
    - Default settings
- Burp Suite project setup screen

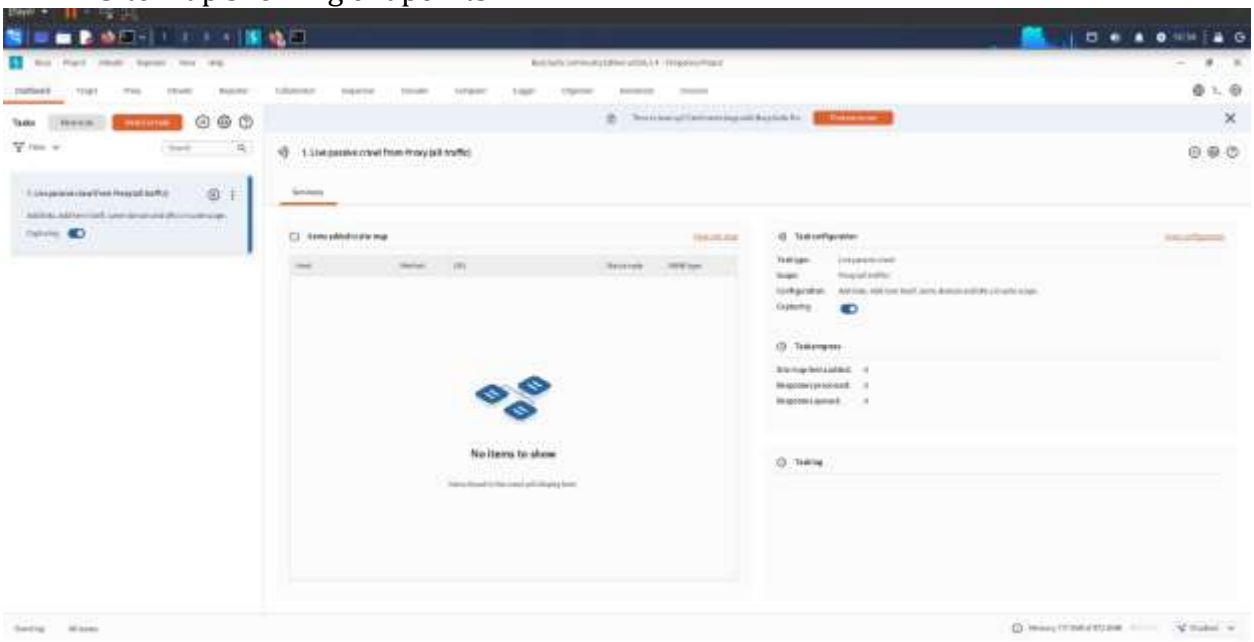


Reconnaissance & Traffic Analysis

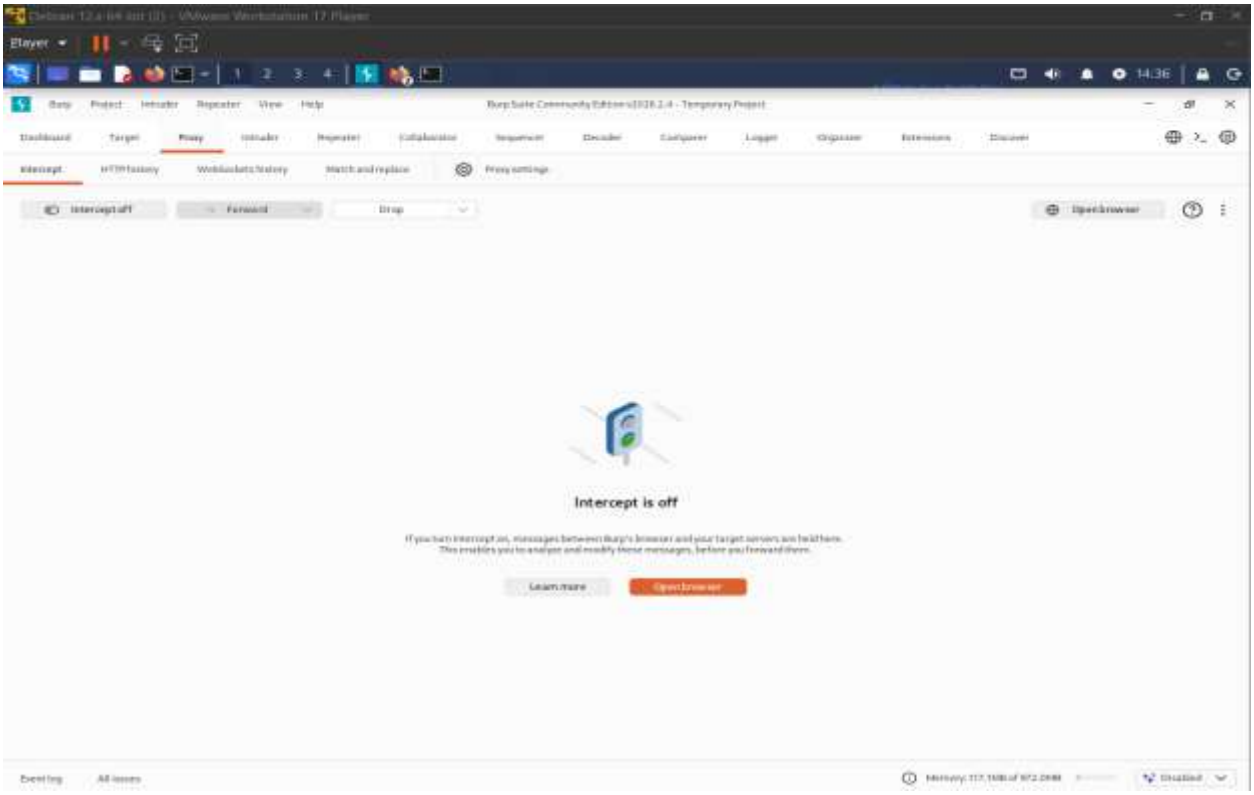
- Enabled proxy interception
- Captured:
    - HTTP requests
    - API endpoints
    - WebSocket traffic
- Burp Proxy capturing requests



- Site map showing endpoints



- WebSocket communication



Week 2 – Vulnerability Exploitation

---

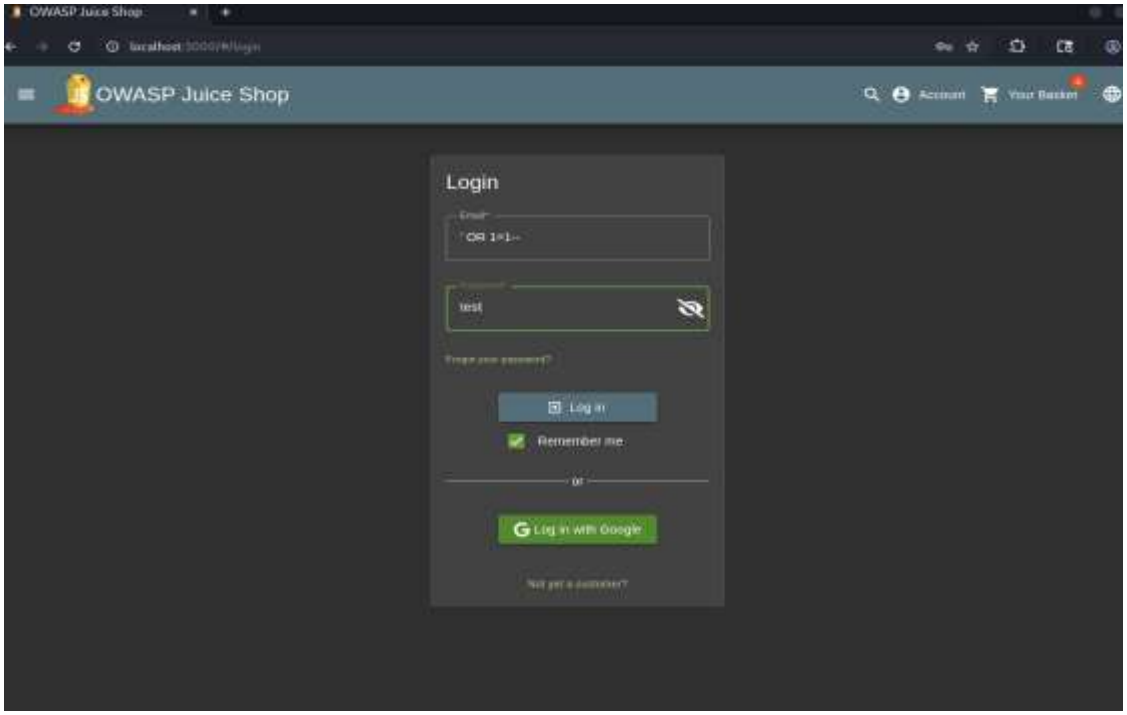
1. SQL Injection (Login Bypass)

Steps

- Navigated to login page
- Injected payload:

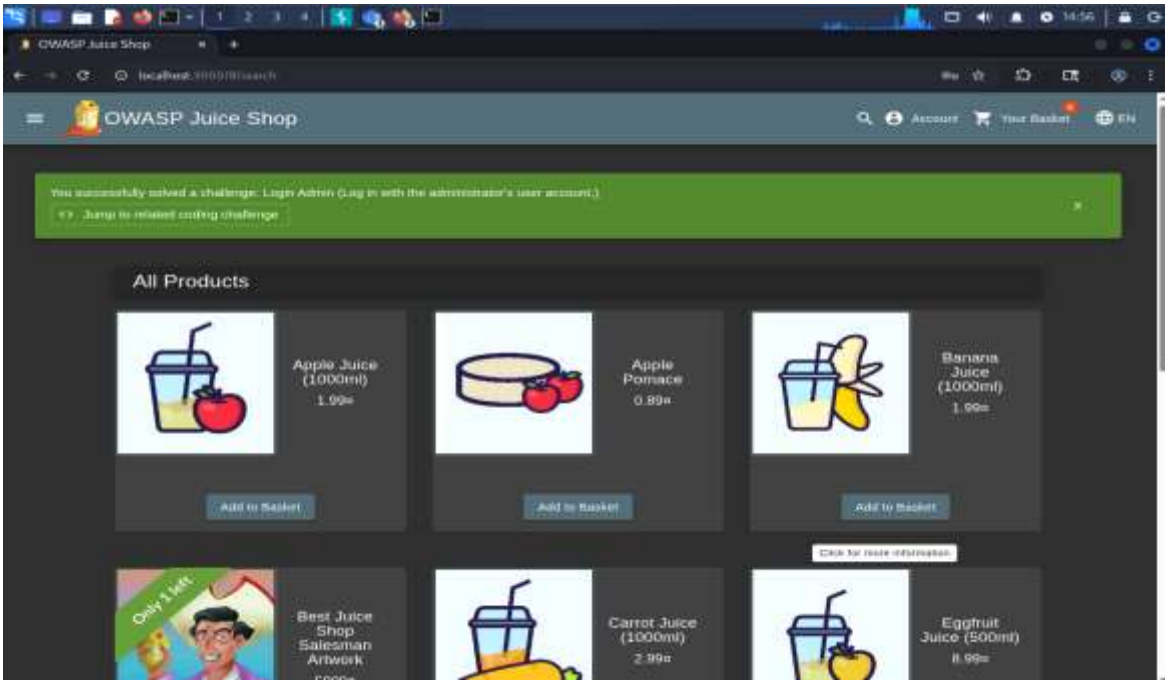
' OR 1=1—

- Login page with SQL injection payload



Result

- Successfully logged in as admin



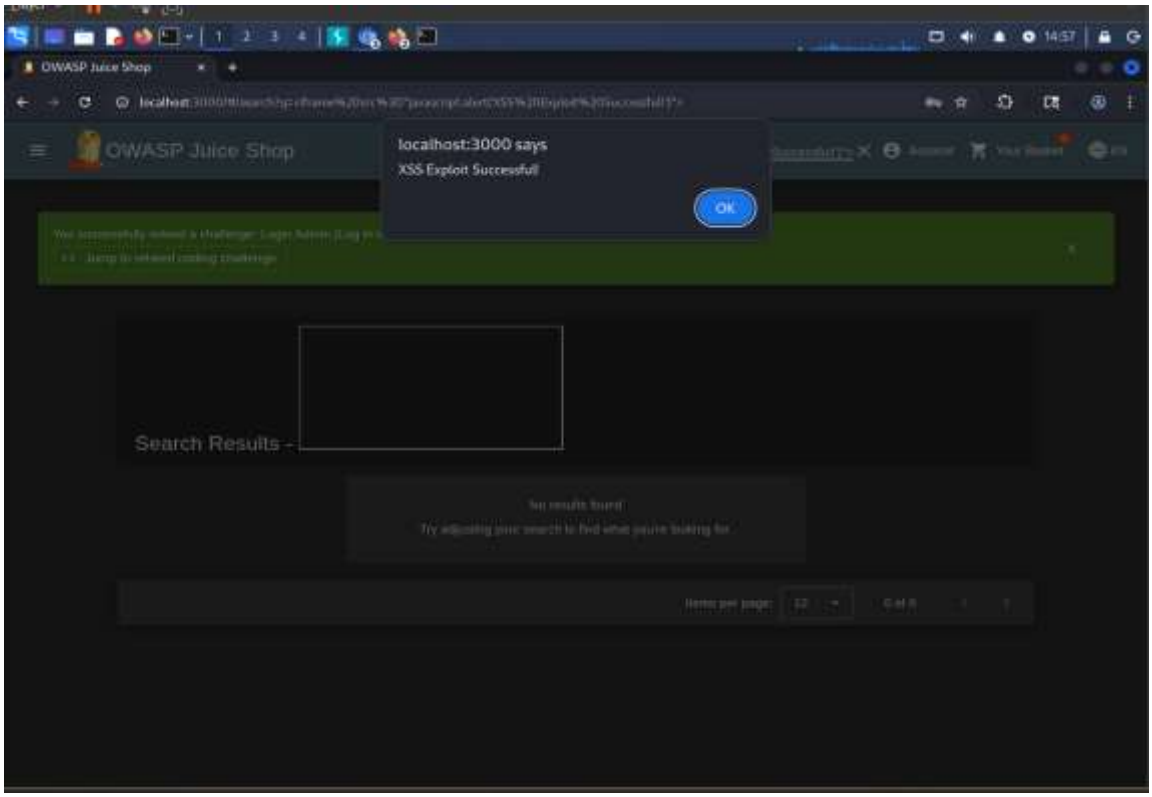
2. Cross-Site Scripting (XSS)

Steps

- Injected payload in search:
- <iframe src="javascript:alert('XSS Exploit Successful!')">
- XSS payload in URL/search

Result

- Alert popup triggered
- XSS alert popup confirmation



3. Sensitive Data Exposure (/ftp)

Steps

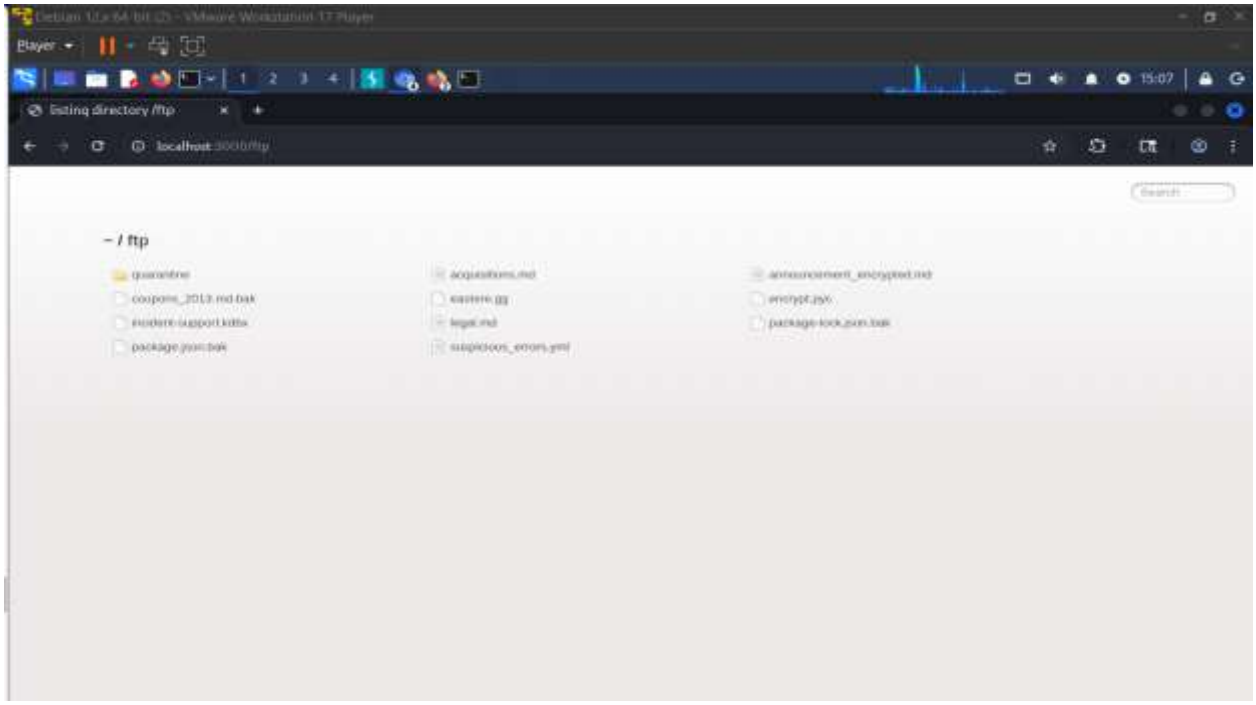
- Accessed:

http://localhost:3000/ftp

- Exposed /ftp directory

Findings

- Sensitive files:



4. Broken Authentication

Observation

- No rate limiting on login attempts
- Can perform brute force

Conclusion:

In Week 1 and Week 2, the testing environment was successfully set up using Docker and OWASP Juice Shop, and reconnaissance was performed using Burp Suite. Key vulnerabilities such as SQL Injection and Cross-Site Scripting (XSS) were identified and exploited. Issues related to broken authentication and sensitive data exposure were also observed. These findings highlight critical security weaknesses in the application. Overall, this phase provided practical experience in detecting and exploiting OWASP Top 10 vulnerabilities.